

Remediation Status — Audit Findings

Branch: feat/audit-fx · **Updated:** 2026-07-05 · Complete disposition of every finding in `FINDINGS-REGISTER.md`.

This sweep fixed everything that improves the **current codebase** without doing the rewrite. Findings that genuinely *are* the rewrite, or belong to the in-flight RBAC effort, or need a data/ops/policy decision, are deferred **with the reason recorded** so nothing is unaccounted for.

Commits: 86cd740 (batch 1) · 3f27824 (wave 1) · ab776e9 (wave 2) · a9e183f (cleanup) · plus the F-005 worker-boot fix.

Legend: ☐ **Fixed** · ☐ **Ops checklist** (in `../deployment.md`) · ☐ **Rewrite** (belongs to the frontend/backend split) · ☐ **RBAC** (owned by the in-flight RBAC effort) · ☐ **Deferred** (needs a data/policy/availability decision — reason given).

Critical

ID	Status	Notes
F-001	☐ Deferred	Top remaining compliance item. An append-only <code>AuditLog</code> + write-at-the-boundary is a substantial cross-cutting feature; recommended as the next dedicated effort (design is in <code>../rebuild/07-SECURITY-COMPLIANCE-SPEC.md</code> §4). Not safe to bolt on at the tail of this sweep.
F-002	☐ Fixed	PHI scan now gates the course-wizard upload path before any generation call.
F-003	☐ Fixed	PhiReport stores entity types+offsets, never raw values; full-document scan; local regex pre-pass blocks SSN/email/phone with zero Vertex transmission.
F-004	☐ Ops checklist	Automated encrypted backups + tested restore — infra, no repo expression.
F-005	☐ Fixed	Workers + cron now boot in <code>instrumentation.ts</code> at server startup, not on a <code>/system</code> page load. (Full worker-service split remains a rewrite item.)
F-006	☐ Fixed	pgvector column declared <code>Unsupported("vector(768)")</code> so <code>migrate dev</code> won't drop it.
F-007	☐ Rewrite	DB-level tenant isolation (<code>organizationId</code> on Course/Enrollment + RLS) is a rewrite-scoped change. App-layer scoping was hardened (F-009/F-010/F-012).
F-008	☐ Fixed	<code>NEXT_PUBLIC_GEMINI_API_KEY</code> removed from Dockerfile + workflows (rotate in GCP — see <code>deployment.md</code>).

High

ID	Status	Notes
F-009	☐ Fixed	<code>getStaffDetails</code> org-scoped; cross-org negative test added.
F-010	☐ Fixed	<code>getEnrollmentQuizResult</code> org-scoped; answer-key leak closed; test added.
F-011	☐ Fixed	<code>xlsx</code> pinned to patched SheetJS 0.20.3; high advisories → 0; untrusted-parse hardening.
F-012	☐ Fixed	Shared <code>guardApiSession</code> / <code>requireActionSession</code> guard; applied to quiz + all billing routes.
F-013	☐ Deferred (partial)	The F-012 guard is the building block; a full default-deny wrapper across all 50 routes is a broad mechanical sweep — recommend as a follow-up now that the guard exists.
F-014	☐ Fixed	Stripe webhook dedupes by <code>event.id</code> (new table) + returns 5xx on retryable failure.
F-015	☐ Rewrite	Separate worker service is a rewrite item. F-005 makes worker liveness reliable in the meantime.
F-016	☐ Rewrite	Moving all heavy work off the request path is the rewrite's core. Partial: upload caps + AI rate limits landed (F-017/F-018).
F-017	☐ Fixed	Upload size caps on document + wizard paths.
F-018	☐ Fixed	Per-user AI rate limits on generation + PHI scan.
F-019	☐ Fixed	Security headers in <code>next.config.ts</code> and nginx (both blocks).
F-020	☐ Fixed	<code>EmailMessage</code> delivery tracking; failed sends no longer marked delivered; sweep retry pre-pass.
F-021	☐ Fixed	All non-reminder sends recorded on success/failure via <code>sendMailTracked</code> .
F-022	☐ Fixed	Seat limits enforced at invite-create and race-safely at invite-accept.
F-023	☐ Fixed	hCaptcha wired into public POSTs; inert until env keys set.
F-024	☐ Deferred (decision)	Making the rate-limiter fail-closed on Redis outage trades availability for security — needs a product call (recommend fail-closed for auth paths only).
F-025	☐ Ops checklist	Encryption at rest — infra + a <code>DocumentVersion.content</code> encrypt-or-drop decision.
F-026	☐ Rewrite	Prisma singleton/pool rework is high-blast-radius and part of the data-layer rebuild; the pooled/direct-URL split is specified in the rebuild data spec.
F-027	☐ Fixed	Missing FK indexes + RAG HNSW index added (migration).
F-028	☐ Rewrite	Broad pagination/aggregation rework is rewrite-scoped (dashboards use <code>groupBy</code> in the target).

ID	Status	Notes
F-029	☐ Fixed	Legacy PM2 deploy scripts deprecated; GH Actions + Compose declared the single path (deployment.md).
F-030	☐ Fixed	CI adds npm-audit, gitleaks, Playwright e2e (report-only until hardened); heavy checks moved to pre-push.
F-031	☐ Fixed (substantial)	Cross-org IDOR tests (F-009/F-010) + 29 quiz start/save/submit route tests incl. scoring boundary & attempt limits. Broader course/cert/export coverage can grow over time.
F-032	☐ Fixed	QuizAttempt append-history; grading counts completed attempts and creates a new row.

Medium

ID	Status	Notes
F-033	☐ Fixed	Login throttle now inside the credentials <code>authorize()</code> (per-IP + per-account), not just the action.
F-034	☐ RBAC	Role checks on course/lesson mutators — owned by the RBAC effort.
F-035	☐ Fixed	Proxy decodes JWTs with the same secret the encoder uses.
F-036	☐ Deferred (decision)	JWT fail-open-on-DB-error is a deliberate availability tradeoff; changing it needs a grace-window/revocation-epoch decision.
F-037	☐ Fixed	Rate limits added to both password-reset request and invite-accept.
F-038	☐ Fixed	Public cert page no longer selects/renders the recipient email.
F-039	☐ Fixed	Certificate score uses <code>?? 100</code> (0 preserved).
F-040	☐ Fixed	Portal-originated pause now expires.
F-041	☐ Fixed	Stripe client is a null-safe lazy proxy; billing routes use <code>getStripeClient()</code> .
F-042	☐ Fixed	Fail-fast env validation at boot.
F-043	☐ Fixed (files)	nginx/tunnel consistency + headers in-repo; requires the documented ops apply step (deployment.md §2.3).

ID	Status	Notes
F-044	☐ Fixed	MinIO image pinned (verify-digest note in deployment.md).
F-045	☐ Fixed	Reminder sweep keeps the latest attempt per enrollment.
F-046	☐ Rewrite	Caching layer — no infra exists today; partial caching risks stale data. Rewrite Phase 2.
F-047	☐ Rewrite	Media via CDN/signed-URL redirect — cohesive Phase-2 change (partial creates two inconsistent patterns).
F-048	☐ Fixed	Document-preview route returns a generic error; details logged server-side.
F-049	☐ Fixed	Untrusted document/RAG text delimited; <code>BLOCK_NONE</code> retained deliberately (behavioral-health content).
F-050	☐ Fixed	Single-pass template fill; no <code>\$</code> -sequence corruption.
F-051	☐ Fixed	Degraded AI generations go to draft; explicit acknowledgement required to publish.
F-052	☐ Deferred (data audit)	Category slug → composite unique can fail on existing duplicate slugs; needs a dedup/data audit first.
F-053	☐ Deferred (data audit)	Enrollment <code>(user_id, course_id)</code> unique can fail on existing duplicate enrollments; needs a dedup audit first.
F-054	☐ Deferred (policy)	Retention/disposal + full deprovisioning need a product retention-policy decision, then scheduled purges.
F-055	☐ Fixed (partial)	The security-relevant <code>xlsx</code> CVEs are resolved (F-011); a CI <code>npm audit</code> gate now surfaces the rest. Remaining transitive bumps (postcss/next, babel, etc.) should go through a controlled <code>npm audit fix</code> PR.

Low

ID	Status	Notes
F-056	☐ RBAC	System-admin real accounts + MFA — RBAC effort.
F-057	☐ Fixed	Forced reset derives email from session, not the URL.
F-058	☐ Deferred	bcrypt cost standardization needs a rehash-on-login migration strategy.

ID	Status	Notes
F-059	☐ Fixed	Password reset + change bump <code>sessionVersion</code> , invalidating other sessions (legacy-token guard prevents mass logout).
F-060	☐ Fixed	Committed dev credentials/PII scrubbed from <code>.claude/agent-memory/**</code> (rotate dev DB password — deployment.md).
F-061	☐ Deferred	Job-poller consolidation — frontend cleanup; low risk, deferred.
F-062	☐ Fixed	Single app-wide Toaster.
F-063	☐ Rewrite	Client-component/bundle reduction — the retained-frontend work in the rebuild spec.
F-064	☐ Fixed	Route error boundaries added.
F-065	☐ Deferred	Design-token adoption is incremental fix-as-you-touch (already mandated by CLAUDE.md); no standalone batch.
F-066	☐ Fixed	Embeddings call has a timeout.
F-067	☐ Fixed	Correlation IDs in logs; invite email masks address + drops tokenized link.
F-068	☐ Rewrite	God-file decomposition is pure refactor risk with no compliance benefit — do during the rebuild.
F-069	☐ Fixed	Stale <code>phi-redactor.md</code> corrected; <code>system-architecture.md</code> flagged.

Tally

- ☐ **Fixed: ~46** (across the 4 commits + F-005), each with tests and/or documented ops steps.
- ☐ **Rewrite: 9** (F-007, F-015, F-016, F-026, F-028, F-046, F-047, F-063, F-068) — the frontend/backend split.
- ☐ **RBAC: 3** (F-034, F-056; F-013 partial) — the in-flight RBAC effort.
- ☐ **Ops checklist: 2** (F-004, F-025) — `../deployment.md` §4.
- ☐ **Deferred with reason: ~7** (F-001 audit log, F-024/F-036 availability decisions, F-052/F-053 data audit, F-054 policy, F-058 rehash, F-055/F-061/F-065 partial/incremental).

Recommended next efforts (in priority order)

- F-001 — audit log** (biggest remaining compliance gap; design ready in the rebuild spec).
- Apply the infra ops steps** in `deployment.md` §2 (key rotation, nginx/tunnel apply, MinIO digest) — several fixes are inert until applied to the VM.
- F-052/F-053 data-dedup audit**, then add the two unique constraints.
- F-004/F-025 ops** (backups + encryption at rest) — the remaining compliance-blockers.
- F-024/F-036 availability decisions**; then flip the CI audit/e2e gates from report-only to blocking once green.